Contents

Volume 04 — Industry, Tech & Privacy Foundations **1**
Lecture T22: Industry Perspective — Part 01 1
Lecture T23: Industry Perspective — Part 02 3
Lecture T24: Live Session — Residual Risk, TVA, and Technology-Week Readings 4
Lecture T25: Cybersecurity Technologies — Part 01 6
Lecture T26: Cybersecurity Technologies — Part 02 7
Lecture T27: Foundations of Privacy — Part 01 9
Lecture T28: Foundations of Privacy — Part 02 10
Lecture T29: Foundations of Privacy — Part 03 11

Volume 04 — Industry, Tech & Privacy Foundations

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T22: Industry Perspective — Part 01

Learning focus

- Explain why a cooperative, trust-based internet makes security structurally hard.
- State the five principles the guest uses for a working cybersecurity system (CIA plus accountability and auditability).
- Describe operating-system rings, symmetric vs public–private cryptography, and hash functions as taught.
- Trace how a packet is unwrapped (MAC → IP → port → application) and why TCP and UDP differ.
- Sketch a corporate perimeter (firewall layers, DMZ, proxy) and the two routes an attacker actually uses.

Key terms

Term	Meaning in this lecture
Cyberspace	Connected, interacting systems; built on cooperation and trust
BGP	Big internet route servers; trust “I know the path” without challenge
CIA + 2	Confidentiality, integrity, availability, plus accountability and auditability (non-repudiation)
Logic bomb	Hidden trigger in software (pipeline story)
No war, no peace	Constant conflict without declared war — the guest’s description of cyberspace
OS	Interface human ↔ compute / I/O; the space where battles are fought
Ring 0	Hardware executes all commands; kernel wants this
Symmetric crypto	Same key to lock and unlock; key distribution and later full-history decrypt

Term	Meaning in this lecture
Public / private key	Public locks for a recipient; only their private key unlocks
Hash	One-way, avalanche on one-bit change; integrity / forensics / download checks
MAC / IP / port	NIC identity, network identity, process identity
TCP	Reliable, sequenced, slow by design (acks)
UDP	Fire-and-forget; OK to lose packets for media
LDAP / Kerberos / RADIUS	Unique identification of people on the network
Firewall	Guard at entry/exit implementing strict rules at chosen OSI intelligence
DMZ	Perimeter zone; in this talk, where an intruder hides after a wall crack
Proxy	Records identity; connects networks without treating them as one
Social engineering	Fool a person and skip the technical wall

Distinctions

- Cyberspace insecurity is not only "bad people"; **protocols assume cooperation**.
- A cybersecurity definition is empty unless it names **CIA + accountability + auditability**.
- Published attack statistics are **not the full crime volume** (20–30% reported).
- **Ring 0 vs user space:** thieves want the watchman's cap, not a noisy user-space crime.
- Symmetric shared-key is not just "weaker math"; **you cannot safely ship the key**, and a later key theft decrypts **old** traffic.
- Hash is **not encryption**: you cannot reconstruct data from the digest.
- TCP vs UDP is **reliability vs loss-tolerance**, not "TCP is always better."
- Firewall layers differ by **how much of the packet they inspect**, not by the slogan "block bad guys."

Exam lines

- Trust is the design of the internet (BGP as the extreme); catching rogues is the core challenge.
- Five principles, not only the triad; auditability = non-repudiation.
- First taught "cyber" strike: Cold War **logic bomb** in pipeline-control software.
- OS + applications are the battlefield; **rings** are hardware privilege; kernel wants ring 0.
- Symmetric key: share problem + later total compromise. Asymmetric: public lock, private unlock.
- Hash: one-way, one-bit avalanche, integrity check (MD5 on downloads).
- OSI unwrap: MAC → IP → port; TCP three-way reliability vs UDP streaming.
- Identify people with LDAP/Kerberos/RADIUS; filter packets with layered firewalls;

expect attackers to **sit in the DMZ** after a perimeter hole — or to **phish an employee** and skip the hole.

Lecture T23: Industry Perspective — Part 02

Learning focus

- Explain VPN as a private encrypted tunnel — and why fooling the VPN server is "key to the kingdom."
- Walk the **cyber kill chain** using the Uri commando analogy.
- Separate spray-and-pray crime from focused cyber espionage.
- Define Trojan vs malware, phishing vs spear phishing, C2, DoS vs DDoS, and vulnerability vs exploit vs payload.
- Describe RAT markets, stealers (Vidar), Qbot staging, APTs, the 3 Ds, and the SideCopy / fake `mail-gov.in` campaign.

Key terms

Term	Meaning in this lecture
VPN / VPS	Encrypted tunnel; VPS assigns a private IP so you look on-LAN
Kill chain	Recon → weaponize → deliver → exploit → payload / persist → C2 → act
Trojan	Malware type whose primary job is a **back door** (payload in a payload)
Spear phishing	Researched, one-target phishing
C2 / C&C	Separate machine that pings "alive?" and issues commands
DoS / DDoS	Overwhelm a service; distributed = many sources, volumetric
Vulnerability	Weak link (not automatically exploitable)
Exploit	Weapon that actually breaks through that link
Payload	What runs after the break (often a RAT); deadliest piece
RAT	Remote administration tool; legitimate or criminal
Stealer	Malware that harvests site passwords (Vidar)
Qbot	Random-email → zip/macro → staged Trojan → botnet monetization
APT	Advanced, persistent, will not walk away; expensive to run
3 Ds	Disrupt, degrade, destroy (plus steal/espionage as motive)
Cryptojacking	Hijack machines to mine, or hijack a wallet
SideCopy	APT (Pakistan-affiliated in this talk) using lookalike gov mail tools

Distinctions

- VPN is not "privacy from your ISP" in this lecture; it is **how branches join HQ** — and the **single best impersonation target**.
- Random crime and espionage are **different weapons and different risk of getting caught**, not two names for the same email.
- Malware ⊃ Trojan; a Trojan **can** become ransomware.

- Phishing vs spear phishing is **targeting and research**, which itself tells you motive.
- DoS vs DDoS is **one source vs many**; both are about **capacity**, not clever credentials.
- A vulnerability is not an exploit; an exploit is not the payload. **The payload is the deadliest.**
- Genuine remote-admin tools and criminal RATs share the idea; the market sells **undetectable, subscription-updated** variants.
- Zip attachments exist to **desynchronize what the mail scanner saw from what the user runs**.

Exam lines

- Fool the VPN server = sit on the office LAN with a private IP; weakest VPN in the mesh is the mesh.
- Kill chain = commando raid: recon, right weapon, exploit, payload, C2 callback.
- Spray-and-pray builds botnets from spam; espionage is expensive, focused, and allergic to hitting a researcher.
- Learn V–E–P, C2, Trojan-as-backdoor, spear phishing as a motivation signal, volumetric DDoS.
- RATs are cheap, licensed against AV; stealers (Vidar) siphon passwords from zip-sized droppers.
- Qbot: zip → macros → staged DLL → C2 chooses ransom or ads; social engineering says “don’t call, reply here.”
- APTs do not leave; vaccine-theft and SideCopy fake-gov-app are the Indian-facing examples; think disrupt / degrade / destroy plus steal.

Lecture T24: Live Session — Residual Risk, TVA, and Technology-Week Readings

Learning focus

- Restate the **risk management process** as identify → assess (measure) → control.
- Compute **residual risk** with the **corrected** classroom formula (no “controls subtracted twice”).
- Unpack **loss frequency** and **loss magnitude** into the two probabilities and the impact × exposure story.
- Draw a **TVA** worksheet (threats × assets → vulnerability) and say what you do after you sort it.
- Know that **chapters 6–8 are to be read together** for the cybersecurity-technology weeks, even if the weekly split looks neater on paper.

Key terms

Term	Meaning in this lecture
Assessment	**Measurement**, not a vague essay about risk

Term	Meaning in this lecture
Residual risk	Risk left in the measure: **LF × LM + measurement uncertainty** (corrected)
Loss frequency	P(attack) × P(success | attack); P(success) from **vulnerability** / existing defense
Loss magnitude	Impact of a successful attack, including **% of the asset exposed**
Measurement uncertainty	Added slack because expert/perceptual measures err; **worst-case step-up**
Threat intelligence	Expert (often external) source of likelihood-of-attack data
TVA	Threats × assets worksheet; cell = vulnerability; then likelihood of success
Chapters 6–8	Technology weeks; read as **one block**, not three isolated weeks

Distinctions

- **Control follows measurement.** No number, no control.
- **Likelihood of attack ≠ likelihood of success.** You can be a popular target and still a hard target.
- **Exposure ≠ "the whole box died."** Part of a system can be down.
- Residual risk in **this** hour is **not** "LF × LM − current controls + uncertainty." Current controls are **already inside** LF (via P(success)) and LM if you assessed honestly. Adding a minus term **double-counts** and confused the class.
- Measurement uncertainty is **not** a confession of ignorance to hide; it is a **deliberate conservative add-on**.
- The **industry video** and the **risk-week live session** are different objects. This live hour is formula + TVA + how to read for **technology** weeks.
- Chapter-per-week labels for 6, 7, 8 are **approximate**; **overlaps are expected**.

Exam lines

- Risk week mantra: identify, **measure**, then control — because you cannot control what you cannot measure.
- **Residual risk = LF × LM + measurement uncertainty.** Drop the old "minus % mitigated by current controls" when assessment already assumed those controls.
- LF = P(attack) × P(success); P(attack) from threat intel; P(success) from vulnerability / existing defense.
- LM = impact, with exposure as **percent of asset**.
- Add uncertainty to **step risk up** (worst case), because expert judgment is perceptual.
- TVA: threats down, assets across, vulnerability in the cell; sort; then success likelihood **per vulnerability**.
- For the coming **cybersecurity technologies** weeks, **read textbook chapters 6, 7 and 8 together** (chapter 5 is this risk week).

Lecture T25: Cybersecurity Technologies — Part 01

Learning focus

- Close the risk-management loop: identify → quantitative assessment → **management choice** among five strategies.
- Keep **defence** and **mitigation** from collapsing into each other.
- Justify a control with **ALE, SLE, ACS** (cost–benefit), then **monitor** because estimates are not actuals.
- See today's technology topic as **defence/protection**, complementary to last week's industry session (Mr. Sai).

Key terms

Term	Meaning in this lecture
Residual risk	Risk left after protection; detailed form includes minus existing protection + uncertainty
TVA	Asset–threat map that yields per-asset vulnerability and then risk
Defence	Invest to be ready **before / against** attack; cuts P(success) or exposure
Transfer	Pass operational cyber risk to vendor (outsource, cloud, managed services)
Managed services	Client **owns** assets; provider must keep them available / secure
Mitigation	**After** incident logic: spend to **cut impact** (contingency, hot site)
Acceptance	Informed choice to live with the number (Target comment; campuses)
Termination	Exit the asset or business when security spend cannot be justified
SLE	Single loss expectancy = loss magnitude = AV × exposure factor
ALE	SLE annualized by yearly frequency
ACS	Annualized cost of the safeguard
SP 830	NIST document-risk standard as **named in this lecture**

Distinctions

- Technology this week is **protection / defence**, not a full catalogue of every cyber tool.
- **Defence ≠ mitigation.** Firewall vs hot site. Mitigation **assumes the hit** and cuts **impact**. Using the words as synonyms is **incorrect**.
- Transfer ≠ "we no longer have a problem." **iPremier**. Client can still **own** assets under managed services.
- Cloud is **a** transfer option; transfer also includes classic outsourcing / managed services.
- Acceptance is not laziness if it is an **informed economic** choice; he still says campuses largely **accept**.
- Termination is a real fifth option, not a joke.
- **ALE post should be lower than ALE prior** (losses), even though you added ACS.
- A control with huge ACS can **fail CBA** even if it "improves security."

Exam lines

- Close risk with **five management options**; defence is only one, and it must pay for itself.
- TVA and per-asset residual risk go to management as a **comparative scale**.
- Transfer: outsourcing, cloud, managed services (ownership may stay); vendor must be competent (**iPremier**).
- Mitigation = contingency / hot site / impact reduction, **not** "another word for firewall."
- Acceptance (Target 70B vs 500M; academia) and termination (kill the unit) are rational when the economics say so.
- **SLE → ALE; compare ALE prior with ALE post + ACS.** Positive gain justifies the safeguard; then monitor.
- Next: what those defence and mitigation **technologies** actually are (managerial overview).

Lecture T26: Cybersecurity Technologies — Part 02

Learning focus

- Place access control, firewalls/DMZ, and cryptography as three **protection** families for CIA.
- Walk **identification → authentication → authorization → accountability** and the authentication factors actually named (password, passphrase, OTP, MFA, biometrics, voice/signature).
- Evaluate biometrics with **FAR, FRR, CER**, using the Andhra ration / worn-ridge case and the CAT-score analogy.
- State what a **firewall rule** does, what **trusted / untrusted / DMZ** mean here, and why cryptography **does not control access** but hides meaning.
- Contrast **symmetric vs asymmetric** key management, **digital signature** (reversed keys, non-repudiation), **digital certificates**, and the three cipher techniques (substitution, transposition, XOR).

Key terms

Term	Meaning in this lecture
Power asymmetry	Surveillance tech in the hands of government vs the governed (1984)
IAAA	Identify, authenticate, authorize, account
Passphrase	Phrase, not a word; harder to crack than a password
MFA	More than one factor, often a second **device** (OTP)
FAR / FRR / CER	False accept, false reject, crossover (device spec to check)
Trusted network	**Your** internal assets / data center
Untrusted network	Everything outside the organization
DMZ	Demilitarized zone: **replica** offered to outsiders via proxy

Term	Meaning in this lecture
Cryptography	Hide meaning **assuming** the channel is already accessed
End-to-end	Encrypted sender→receiver; intermediary (WhatsApp) cannot read
Symmetric	Same key both ways; **key distribution** is the hole
Asymmetric	Public locks, private opens (for confidentiality)
Digital signature	**Private** signs, **public** verifies — **non-repudiation**
Digital certificate	Third-party-managed site identity the browser checks
Caesar	Mono-alphabetic shift **p+k mod 26**
Transposition	Reorder bits in a block by a position key
XOR	Bitwise exclusive-or with a keystream

Distinctions

- This is **managerial awareness**, not crypto course design depth.
- 1984 is **surveillance / private space / power**, not a claim that 2020s India is Oceania.
- Identification is **issuing a unique mark**; authentication is **matching presentation to the store**.
- Password vs passphrase vs OTP vs biometric vs "what you produce" are different **factors**; MFA **combines** them, often across **devices**.
- FAR down **is not free** — FRR goes up (CAT 99.99). CER is the honest spec to read on a device.
- Worn labourers' fingerprints are a **technology** failure with **inclusion** consequences, not user stupidity; **five-finger** fusion was the local fix.
- Firewall **prevents access** by rule; cryptography **does not prevent access** — it prevents **reading**.
- Trusted = **ours**; untrusted = **not ours**. DMZ is a **replica / proxy**, not "the safe room where we stop monitoring" (contrast the industry guest's looser DMZ talk in T22).

Exam lines

- Protection stack taught today: **IAAA access control** (IDs, MFA, biometrics with CER), **firewall + DMZ/proxy**, **cryptography** (hide meaning on an untrusted path).
- 1984 and Minority Report frame surveillance power and biometric access.
- SBI MFA and Krishna-district five-finger rations are the Indian working examples; FAR/FRR trade-off is the CAT story.
- Symmetric = one key you cannot safely ship. Asymmetric = public lock / private unlock. Reverse the keys for **signatures and certificates** (Passport Seva, company filings, HTTPS padlock).
- Three primitive techniques: Caesar **p+k mod 26**, transposition of 8-bit blocks, XOR truth table. Standards come next class; active-defense presentation follows this hour.

Lecture T27: Foundations of Privacy — Part 01

Learning focus

- Finish the technology block: why encryption is "the heart of the matter," blockchain's CIA/hash story, and the **DES → 3DES / AES / RSA** ladder.
- Separate **"encryption was cracked"** from **backup / storage was in plaintext** (celebrity WhatsApp + NCB).
- State why privacy is **not an absolute right** (public interest, national security, Indian Telegraph Act 1885) and how **party-in-power vs opposition** flip the slogan.
- Use **Big Brother, Foucault, panopticon**, and the **IIT hostel CCD** fight as the surveillance teaching.
- Quote the classical definition: **"the right to be let alone"** (Warren & Brandeis, 1890, Kodak) and the Greek **polis / oikos** split; note reductionism vs coherentism.

Key terms

Term	Meaning in this lecture
Heart of the matter	Encryption — without it, no trustworthy e-commerce
DES	IBM 64-block / 56-bit; broken; led to RSA fame
AES	Widely used NIST/ISO standard; 128/192/256-bit keys
Immutability	Blockchain integrity via **hash** of each block
Backup gap	E2E in transit ≠ encryption of **cloud chat backup**
Public interest / national security	Media and state justifications that **qualify** privacy
Big Brother	Orwell's name for the power centre that watches
Panopticon	Observe all from one point; subject may not know
Indian Telegraph Act 1885	Legal tap of communications; not repealed
Right to be let alone	Warren & Brandeis 1890 — classical **privacy**
Autonomy	The freedom-stake that privacy is about
Polis / oikos	Aristotle's public vs private spaces
Reductionism vs coherentism	Privacy already inside "freedom" vs privacy as its own concept

Distinctions

- **Access control ≠ encryption.** Encryption is what you do **after** someone may still see the bits.
- He has **not** seen a standard-ciphertext broken in the wild; **do not** use the celebrity chats as "WhatsApp crypto failed."
- Backup / Drive / credentials are a **different surface** from E2E.
- Getting the chats for **investigation** is not the same as **TV broadcasting** them.

- Privacy is **not absolute**; national security is the court's cave-in; **politics flips** the slogan.
- Security cameras can be **welfare** and **abuse**; panopticon is the name of one-point watch.
- **Corridor vs room** is the live privacy boundary on campus.
- Collectivist postcard culture ≠ "Indians never had privacy"; **consciousness** of the individual right is late and partly **Western-framed**.

Exam lines

- Close tech: encryption underpins e-commerce; DES died to RSA; AES/RSA key lengths make brute force "virtual" fantasy; blockchain = encrypt + private-key non-repudiation + hash immutability.
- Open privacy with a case where **crypto worked** and **backup + media** did not.
- Big Brother / Foucault / Telegraph Act 1885 / panopticon / IIT cameras: **power asymmetry**, informed surveillance, public vs private **place**.
- Warren & Brandeis 1890, Kodak, **right to be let alone**, Pitt's hut, Aristotle's two spaces, reductionism vs coherentism.
- Next lectures move from this general privacy to **information privacy** (T28) and the We Googled You case (T29).

Lecture T28: Foundations of Privacy — Part 02

Learning focus

- Place economic and feminist **views of privacy** beside the "let alone" tradition.
- Quote **Alan Westin's** definition and use it to split **privacy** from **information privacy**.
- List the **Fair Information Practice Principles (FIPP / FIPPs)** as taught from the 1973 US advisory report — including Aadhaar-style **collect only what you need**.
- Name the three entities **data subject / controller / processor** (and India's principal / fiduciary / processor).
- Measure **concern for information privacy (CFIP)** on four dimensions: collection, unauthorized access, errors, secondary use.

Key terms

Term	Meaning in this lecture
Posner 1975	Privacy matters to economists when it has **economic consequence**
Westin	Control over **when, how, to what extent** information is communicated
Information privacy	Decide what you share; not the same as physical "let alone"
FIPP / FIPPs	1973 Fair Information Practice Principles — template for later law
Secret systems	Forbidden: the **existence** of the file must not be hidden

Term	Meaning in this lecture
Purpose / consent	No **secondary use** without the person's consent
Data subject	The individual (India draft: **principal**)
Data controller	Collects and **decides** (India draft: **fiduciary**)
Data processor	Third party (or same org) that **processes**
CFIP	Measurable **concern**: collection, unauthorized access, errors, secondary use
Profiling	Credit bureaus / merchants building a picture of you
Retire vs delete	Platforms may stop showing you and still **keep** the record

Distinctions

- **Privacy** (let alone, body and home) is not **information privacy** (control of **disclosure**).
- Economists ignore privacy **until liability / theft shows up in money**.
- A locked family door can be **protection** or a **cover for abuse** — feminist critique of "private."
- FIPP-1 is about the **existence** of the system, not only the accuracy of rows.
- Shaadi-style **perpetual license** is exactly the **secondary-use** problem FIPP-3 targets — **read the policy**.
- **Security spend** is not a separate "IT hobby": under FIPP it is a **privacy duty** of the collector; breach = principle broken.
- Controller **decides**; processor **handles**; they may be the same legal person.
- India's dropped PDP bill **renamed** the roles (principal / fiduciary) without throwing the triad away.

Exam lines

- Westin: information privacy = **control over communication of information about you**.
- 1973 FIPPs (no secret files, access, purpose/consent, correction, minimization, collector security) underlie GDPR-style law.
- Subject / controller / processor (principal / fiduciary / processor).
- CFIP = collection + unauthorized access + errors + secondary use (GATE DOB).
- Orgs worry because of **liability**; people worry because of **harm and embarrassment**; credit bureaus show the profiling machine; **We Googled You** is next.

Lecture T29: Foundations of Privacy — Part 03

Learning focus

- Reconstruct the **Hathaway Jones / Mimi Brewster** case as the lecture actually argued it (facts, stakeholders, two exam questions).
- Separate **"it was public, so not a privacy violation"** from **"on what ground may you reject, and must you disclose the Google search?"**

- List the **policy layers** the student team mapped (FCRA, GDPR consent-to-check, EEOC, NLRA, HIPAA) and the screening hygiene they proposed.
- Hear the instructor's pushback: **authoritarian China**, Tiananmen, **organizational legitimacy**, inner HR–CEO politics, and why "keep her in the US" may **defeat the hire**.
- Translate the case into **personal** practice: do not vanish online; **Google yourself**; professional vs private accounts.

Key terms

Term	Meaning in this lecture
Invasive background check	More personal data than the job needs (status, credit, health, race)
We Googled You	HBR-style case: luxury firm, China expansion, Google dirt on the hire
Public domain argument	If press already published it, reading it is not secret surveillance — **but rejection reason still regulated**
Screening policy	Written, layered, job-relevant, transparent — so HR is not improvising with lawyers
GDPR (as applied here)	**Awareness / explicit consent** before checking **EU** people
EEOC / NLRA / HIPAA / FCRA	Anti-discrimination, protected concerted activity, health data, credit/consumer data
Legitimacy	Firm's ability to operate in a host polity (China) without political blowback
Digital vanishing	Empty search can look like **hiding**; worse than a cleaned professional page
Google yourself	Recurring self-audit (+ alerts) of what employers will see

Distinctions

- **Public ≠ anything-goes rejection.** Reading page nine may not violate secrecy; **rejecting for ideology, race, health, or union-like protest** can still be illegal or illegitimate.
- Telling Mimi "we Googled you" is a **separate** legal/PR risk from doing the search.
- Confronting her does **not** dissolve the **China** problem; the activism **stays Googleable**.
- Parking her in the US **may save face and lose the reason she was uniquely valuable**.
- **Authoritarian** host vs **democratic labour statutes** (NLRA) — the slide stack is Western; **Tiananmen** is the instructor's correction.
- Inner-circle **politics** can dress up as "privacy diligence."
- Erasing your whole footprint is not "more private" to employers — it reads as **concealment**.
- Fake internet content exists — **hear the candidate** before treating Google as a court.

Exam lines

- We Googled You: Fred wants Mimi for China; Virginia's nine-page search finds old **anti-WTO** and **anti-China-government** protests; lawyers enter.
- Privacy analysis: **public records / press** vs **how far** and **why you use** them; write a **layered screening policy**; GDPR-style **notice**; keep health and protected classes out.
- Business analysis: hire → China legitimacy and competitor attacks; don't hire → **discrimination** suit and she goes to a rival.
- Instructor's exam-level complexity: **credentials vs authoritarian politics vs org politics**; via media (confront, probation) without pretending the host state is a liberal campus.
- For you as a candidate: **Google yourself**, keep a **professional** public trail, do not assume delete = gone.
